

AI Vendor Risk — 12-Point Board Checklist

NIST AI RMF 1.1 + EU AI Act mapped • For CFO / Audit Committee / Board

Published by AI Times — Editorial signals for C-suite on AI, governance, and infrastructure. Free distribution with attribution.

When to use

Before you sign — or renew — any AI vendor contract, run these 12 questions through the proposed agreement. If 9+ have documented answers, proceed. If <5, **renegotiate or walk**.

This checklist maps each question to **NIST AI Risk Management Framework 1.1** (Govern / Map / Measure / Manage) and **EU AI Act 2024/1689** (high-risk Article 9 obligations). Use it as your board-level documentation artifact.

A. Legal Entity & Liability (Questions 1-3)

1. Legal entity name in the proposed contract — does it match the entity your data flows to?

- **Why:** OpenAI restructured Q1 2026 — many DPAs signed pre-restructure now reference a defunct entity. Same risk for Anthropic, xAI, Mistral as ownership maps shift.
- **NIST:** GOVERN-1.3 (Roles and responsibilities clearly documented)
- **EU AI Act:** Art. 9 §2(a) — risk management system documentation
- **Red flag:** vendor uses "Group" or "Affiliate" language without naming the specific entity

2. Liability cap — what's the per-incident and aggregate ceiling?

- **Why:** Most AI vendor contracts cap liability at 12× monthly fee. A €10M brand-damage incident on a €100k/year contract = €100k recoverable.
- **Negotiate:** uncapped for IP infringement, data breaches, regulatory fines passed-through to you
- **Red flag:** "Vendor liability limited to amounts paid in prior 12 months"

3. Hold-harmless from regulatory penalties — who pays EU AI Act fines?

- **Why:** EU AI Act §99 — fines up to €35M or 7% global revenue. Your vendor's compliance failure = your fine.
- **Demand:** explicit indemnification for AI Act, GDPR, NY State CIDC, Colorado SB 205
- **Red flag:** silence on regulatory fines = vendor passes risk to you

B. Data Boundaries (Questions 4-6)

4. **Training data scope** — is your data, including prompts, used for vendor's model training?

- **Why:** Even with "no training" toggle, many vendors reserve right to use data for "service improvement," "safety tuning," "abuse detection."
- **Demand:** explicit "Customer Data and Customer Prompts shall not be used for any model training, fine-tuning, RLHF, or evaluation"
- **NIST:** MAP-3.3 (Data sources and quality documented)
- **EU AI Act:** Art. 10 §2-5 (data governance)

5. **Sub-processors** — list every entity that touches your data, including the LLM provider hosting your fine-tuned model

- **Why:** Vendor X uses Anthropic. Anthropic uses AWS. AWS uses Cloudflare. Each link is a sub-processor with its own DPA terms.
- **Demand:** complete sub-processor list with audit rights and 30-day change notice
- **Red flag:** "Sub-processors listed at vendor.com/subprocessors" with no notification commitment

6. **Data residency** — where is data stored, processed, and where do model inference servers sit?

- **Why:** GDPR Chapter V transfers, US CLOUD Act exposure, China DSL compliance. Each jurisdiction is a separate risk.
- **Demand:** named regions, sovereign cloud option, kill-switch on geo-shift
- **EU AI Act:** Art. 14 (transparency on system location)

C. Operational Risk (Questions 7-9)

7. **Model card** — is the exact model version, training cutoff, and known limitations documented?

- **Why:** "GPT-5" today ≠ "GPT-5" in 6 months. Silent updates change behavior. Your testing baseline becomes invalid.
- **Demand:** explicit notification of model updates, ability to pin version, regression test SLA
- **NIST:** MEASURE-2.1 (system performance evaluation)

8. **Failure mode disclosure** — what does the vendor commit to disclosing when their model misbehaves at scale?

- **Why:** Bing chatbot 2023, Gemini image gen 2024, Grok hallucination incident 2025 — vendors disclosed days/weeks late. Your reputation moves at minutes.
- **Demand:** 24-hour disclosure SLA for systemic incidents affecting your use case
- **NIST:** MANAGE-3.1 (incident response and recovery)

9. Performance SLA on hallucination rate — what's the contractual ceiling on factual errors for your use case?

- **Why:** Most AI vendors offer uptime SLA but no accuracy SLA. For high-stakes use (legal, medical, financial advisory) this is the only SLA that matters.
- **Demand:** measurable accuracy commitment + sample-and-grade protocol + credit clause on breach
- **Red flag:** "Best effort" language on factual accuracy

D. Exit & Continuity (Questions 10-12)

10. Data export format — when you terminate, what's the data egress timeline and format?

- **Why:** Vendor lock-in. Your 18 months of conversation logs, fine-tuning data, embeddings — recoverable or stranded?
- **Demand:** standard formats (JSON, Parquet, ONNX for models), 60-day window, no egress fees beyond reasonable infra cost
- **Red flag:** "Data deleted upon termination" without export window

11. Model portability — if you've fine-tuned on your data, can you take the weights with you?

- **Why:** Anthropic, OpenAI generally don't allow weights export. Open-weight providers (Mistral, Llama via partners) do. Lock-in level differs by 10×.
- **Architecture decision:** prefer open-weight providers for mission-critical use cases
- **NIST:** GOVERN-3.2 (workforce/partner alignment)

12. Successor liability — if vendor is acquired or restructures, do your terms survive?

- **Why:** AI vendor M&A is accelerating. OpenAI restructure, xAI-Twitter spin-off, Cognition Labs Series B. Your DPA must follow.
- **Demand:** "Change of Control" clause requiring 90-day notice and right to terminate at no penalty
- **EU AI Act:** Art. 16 (provider obligations transfer)

Scoring & Action

- **9-12 ✓ documented** — proceed with informed consent. Audit annually.
 - **5-8 ✓** — renegotiate before signing. Use this checklist as basis for redlines.
 - **<5 ✓** — walk away. The risk is being passed to you uncompensated.
-

Mapping summary

Section	NIST AI RMF	EU AI Act
A. Legal Entity	GOVERN-1, GOVERN-3	Art. 9, Art. 16, Art. 99
B. Data Boundaries	MAP-3, MAP-5	Art. 10, Art. 14, Chapter V
C. Operational Risk	MEASURE-2, MANAGE-3	Art. 9, Art. 15
D. Exit & Continuity	GOVERN-3	Art. 16, Art. 25

What to do next

1. **Apply this checklist to your top-3 AI vendor contracts** — identify documented gaps.
 2. **Brief your audit committee** — quarterly AI vendor risk review on the agenda.
 3. **Make it a procurement standard** — no AI vendor signs without this checklist passing.
-

References

- NIST AI Risk Management Framework 1.1 — nist.gov/itl/ai-risk-management-framework
 - EU Regulation 2024/1689 (EU AI Act) — eur-lex.europa.eu
 - Colorado SB 205 (2024), California AB 2930 (2024), NY State CIDC Act
 - Boston Consulting Group, "AI Adoption 2024" — bcg.com/publications
 - McKinsey, "The state of AI in 2025"
-

About AI Times

We publish editorial signals on AI policy, governance, and infrastructure for C-suite executives. Daily reels on Instagram. Weekly deep-dives on Beehiiv.

Follow @aittimes on Instagram for daily AI & Crypto signals.

DM keyword "VENDOR" to receive the editable Excel version of this checklist (free for subscribers).

Editorial inquiries: ttimesai@gmail.com

© 2026 AI Times. Published 13 May 2026. Lead magnet — share freely with attribution.